OWASP Juice Shop Vulnerability Testing Report

Tester: Kshatri Bhavya Naga Sai Parvathi
Target: OWASP Juice Shop 19.1.1
Date: 25-02-2026

1. Login as Admin

Vulnerability Type: Authentication Bypass
Description:
The admin login can be bypassed by intercepting the login request and modifying the payload to access administrative privileges.

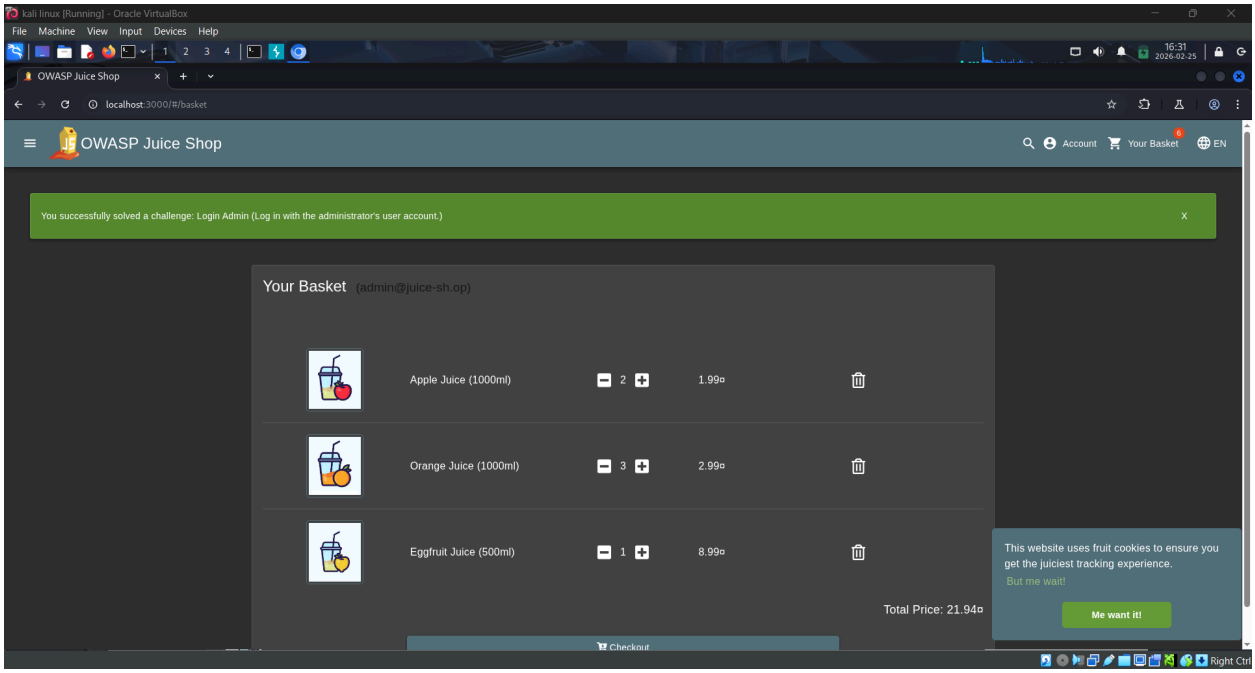
Steps Performed:

1. Opened login page in browser.
2. Intercepted login request using Burp Suite.
3. Modified email to `admin@juice-sh.op` and bypassed password.
4. Logged in successfully as Admin.

Impact:

- Unauthorized access to admin functionalities.
- Compromise of all user data.

Screenshot:



2. View Basket (IDOR)

Vulnerability Type: Insecure Direct Object Reference (IDOR)
Description:
Changing the `basketId` in HTTP requests allowed access to other users' baskets without authorization.

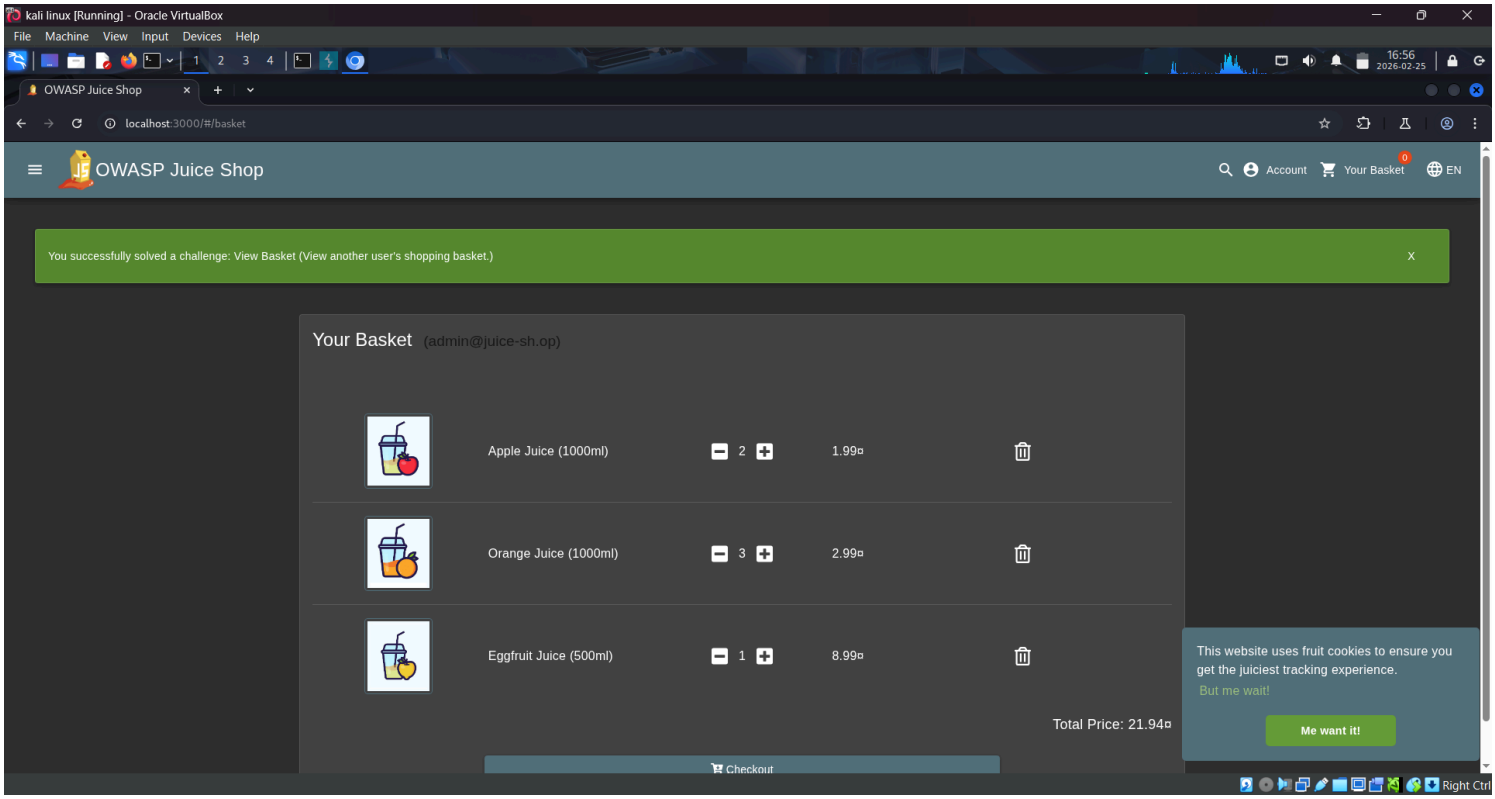
Steps Performed:

1. Logged in as a normal user.
2. Intercepted `GET /rest/basket/{id}` request.
3. Modified `basketId` to another user's basket.
4. Successfully viewed another user's basket.

Impact:

- Unauthorized access to sensitive user data.
- Horizontal privilege escalation.

Screenshot:



3. Score Board Exposure

Vulnerability Type: Sensitive Endpoint Exposure
Description:
The `/score-board` endpoint is exposed without proper access control.

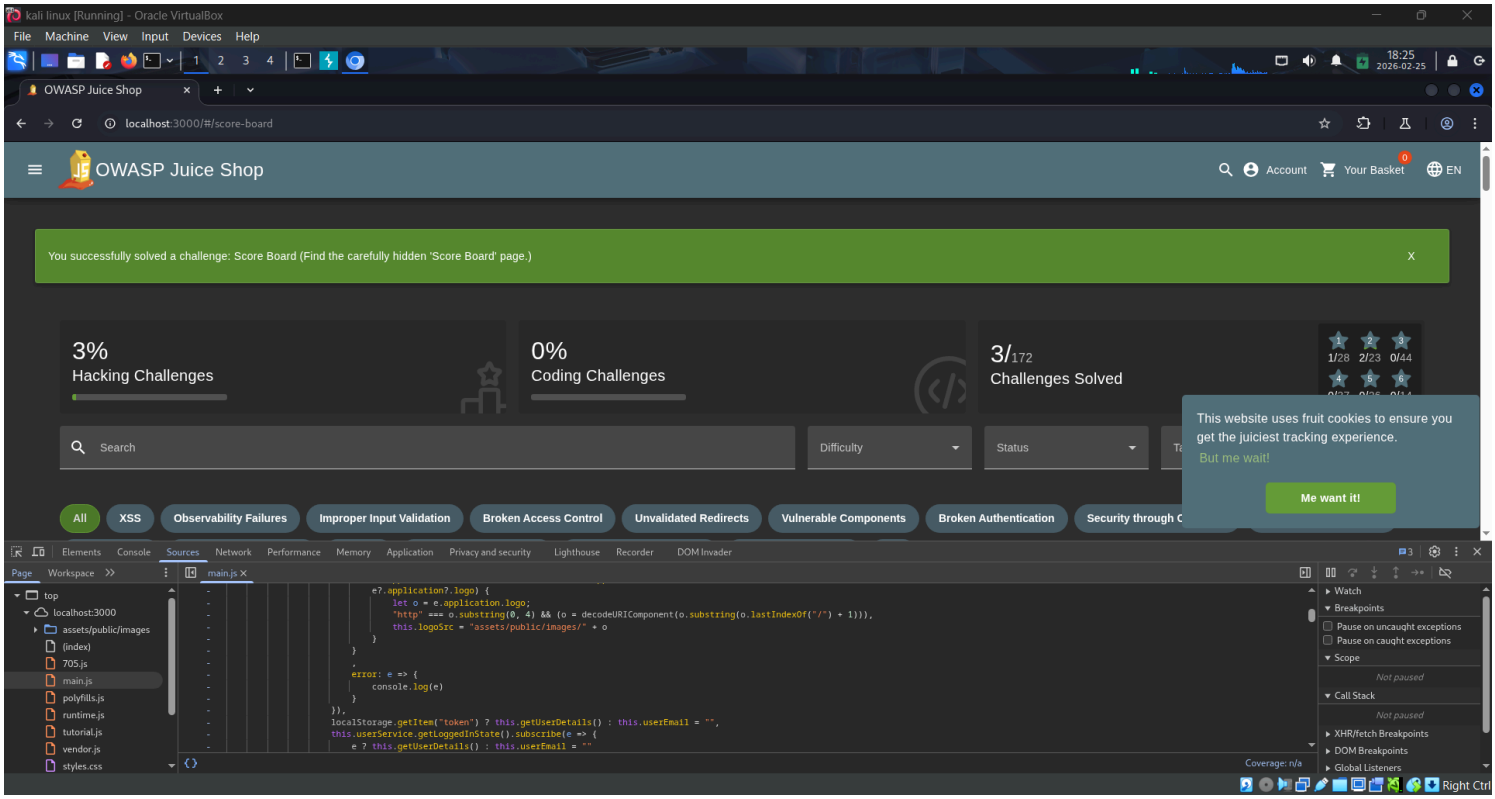
Steps Performed:

1. Accessed `/score-board` URL directly in browser.
2. Scoreboard content displayed without authentication.

Impact:

- Sensitive information exposure.
- Could aid attackers in reconnaissance.

Screenshot:



4. DOM XSS (Cross-Site Scripting)

Vulnerability Type: Client-side XSS
Description:
User input is not properly sanitized in the DOM, allowing script injection.

Steps Performed:

1. Entered payload **<iframe src="javascript:alert(`xss`)">** in search bar.

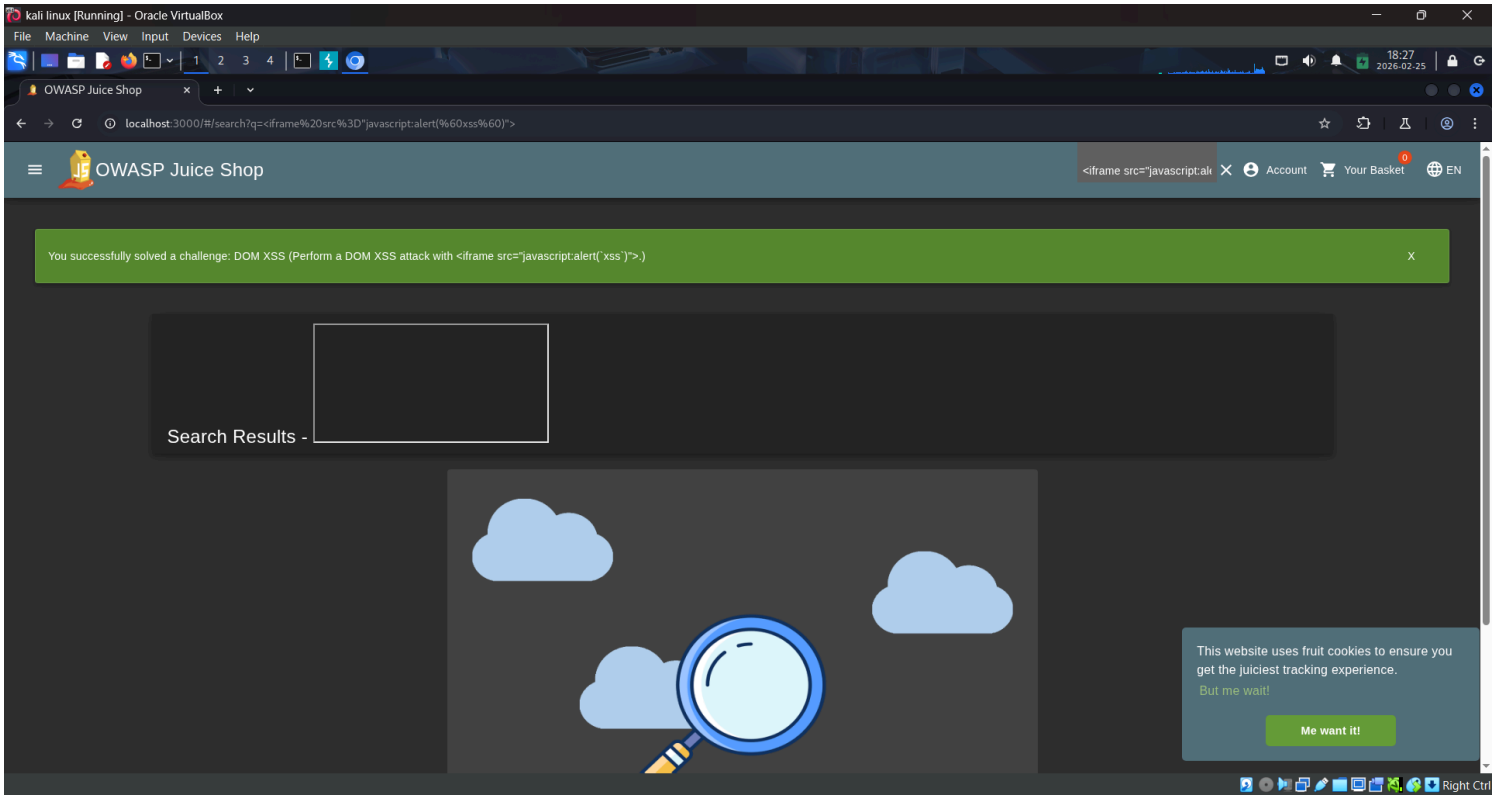
2. Payload executed in the browser without server interaction.

Impact:

- Execution of arbitrary scripts in victim's browser.

- Potential cookie theft, session hijacking.

Screenshot:



5. Bonus Payload / Advanced XSS

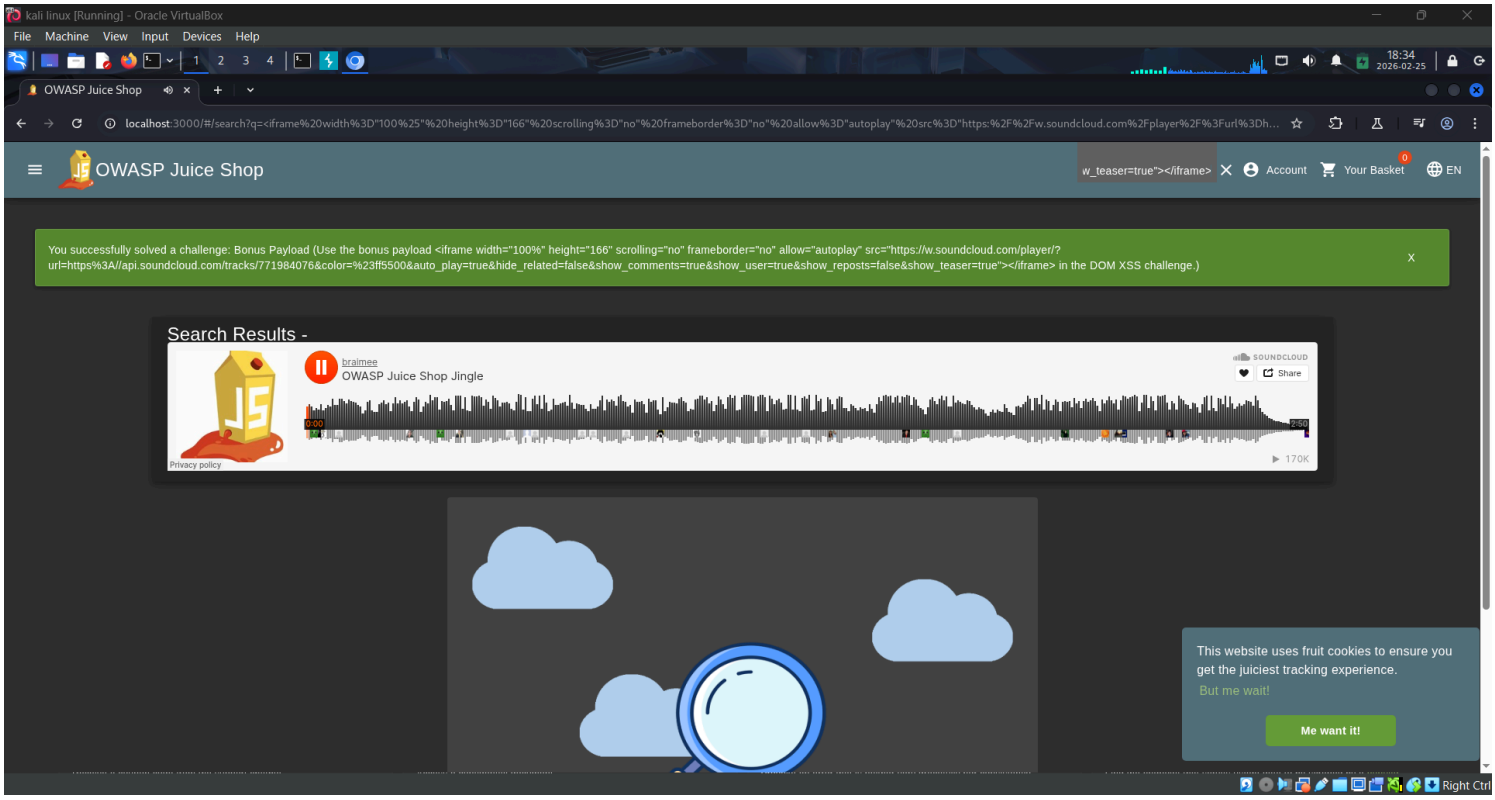
Vulnerability Type: Filter Bypass XSS
Description:
Some input filters can be bypassed using obfuscated or encoded payloads.

Steps Performed:

1. Entered payload `<iframe width="100%" height="166" scrolling="no" frameborder="no" allow="autoplay"src="https://w.soundcloud.com/player/?url=https%3A//api.soundcloud.com/tracks/771984076&color=%23ff5500&auto_play=true&hide_related=false&show_comments=true&show_user=true&show_reposts=false&show_teaser=true"></iframe>` in input field.

2. Payload successfully executed, bypassing basic filters.

Impact:

- Advanced XSS exploitation.
- Demonstrates bypass of client-side input validation.

Screenshot: